JSON 帳密驗證 API

僅驗證帳密；不建立中央 SSO

適合接收系統已有自己的登入頁，確實需要由後端驗證使用者帳密。若希望使用者在中央登入一次就能進入多系統，應改用前述三種單一登入方式。

1. **使用者 → 接收系統登入頁**
   使用者輸入校園帳號與密碼。
2. **接收系統後端 → 中央驗證 API**
   HTTPS + X-Client-Id / Secret + JSON 使用者帳密。
3. **中央驗證呼叫資格**
   檢查服務開關、系統啟用、來源 IP、服務授權與系統密鑰。
4. **中央驗證使用者帳密**
   套用帳號狀態及錯誤鎖定；回傳 verified。
5. **接收系統判斷並建立自己的登入**
   僅 HTTP 200 且 verified === true 可繼續；權限由接收端檢查。

先向 SSO 管理者申請

- 建立「帳密驗證 API / JSON」登記，授予帳密驗證服務；取得 Client ID 與一次顯示的 Client Secret。
- 提供後端實際連出 IP。接受逐筆 IPv4 / IPv6，不接受 * 或網段；代理 / NAT 要核對中央實際看到的 IP。
- 管理者啟用 JSON 服務與系統登記。端點預設關閉，關閉時 HTTP 503。

> 本文件為目前開發版介面規格；正式網址、系統代碼、密鑰 / 憑證、授權欄位與測試帳號請向 SSO 管理者取得。example.edu 為示意位址，不可直接呼叫。

JSON 帳密驗證 API

僅驗證帳密；不建立中央 SSO

請求與回應

位置	欄位	內容
Endpoint	POST	https://sso.example.edu/api/integration/v1/verify
Header	Content-Type	application/json
Header	X-Client-Id / X-Client-Secret	呼叫系統代碼 / 系統密鑰；不同於使用者帳密
JSON	userName / password	string；帳號不可空白且最多 100 字元，密碼不可空且最多 256 字元
HTTP 200 JSON	verified	boolean；true 通過、false 不通過；沒有姓名或其他個資

```
POST /api/integration/v1/verify HTTP/1.1
Host: sso.example.edu
Content-Type: application/json
X-Client-Id: YOUR_CLIENT_ID
X-Client-Secret: YOUR_SECRET

{"userName":"TEST_ACCOUNT","password":"TEST_PASSWORD"}

// 成功處理時的 JSON body（二選一；不含本行註解）
{"verified":true}
{"verified":false}
```

HTTP	意義 / 接收端處理
400	JSON 錯誤或空請求；修正格式。
403	系統未授權、停用、來源 IP 或密鑰不符。
413 / 415	超過 16 KiB / Content-Type 不支援。
429	同來源 IP 每分鐘 60 次限制；延後並避免重試風暴。
503	服務未啟用或來源暫時不可用；顯示稍後再試，不能當登入成功。

> 沒有提供 sub、姓名、身分欄位或 Token，也不會建立中央 Cookie。若需要穩定識別碼及個人資料，請另選適用的 SSO 方式。

JSON 帳密驗證 API

僅驗證帳密；不建立中央 SSO

後端處理示意

```
response = backendPostJson(API, clientHeaders, userCredentials)
if response.status != 200: showServiceError(); stop
if response.json.verified is not true: rejectLogin(); stop
account = requireEnabledLocalAccount(submittedUserName)
checkLocalPermissions(account)
createLocalSession(account)
discardPassword()
```

接收端驗收清單

- 正常、錯誤、空白帳密及停用帳號。
- 錯誤系統密鑰、未授權 IP、停用系統、未勾服務資格。
- HTTP 200 + false 與 HTTP 503 的處理要不同，但都不可登入。
- 密鑰更新後，舊密鑰立即失效。密鑰及使用者密碼不可放在前端或網址。
- 不得把使用者密碼持久化、寫入日誌或錯誤追蹤；驗證完成即釋放。
- 來源中斷或驗證逾時不自動降級成成功。

操作限制

同一使用者五分鐘內連續失敗五次會鎖定五分鐘，JSON / SOAP 與目前校務登入共用嘗試紀錄。不要用真實帳號進行壓力或密碼猜測測試；聯調使用核准的合成測試帳號。

> 中央與接收系統各自建立 Cookie / Session。中央登入有效可省略再次輸入帳密；接收系統仍須完成驗證。中央登出不等於所有下游同時登出，本版未實作完整跨系統單一登出。

> 本文件為目前開發版介面規格；正式網址、系統代碼、密鑰 / 憑證、授權欄位與測試帳號請向 SSO 管理者取得。example.edu 為示意位址，不可直接呼叫。

實作核對：src/NkustSso.Server/Controllers/CredentialVerificationApiController.cs；ApiModels/CredentialVerificationRequest.cs；Services/CredentialVerificationService.cs；Services/IntegrationClientRegistrationService.cs